

Sample Audit Finding

GRC Practicum - Project 6 | NOVAtch Inc. (simulated scenario) | Illustrates the Condition/Criteria/Cause/Consequence structure

Note: NOVAtch Inc. is a fictional company; this finding is simulated for demonstration. The four-part structure and formal language reflect real-world internal audit convention.

Finding reference	AUDIT-2026-08-F1
Finding title	Untimely Access Removal for Terminated Personnel
Severity	HIGH
Control tested	AC-02 (Access to Programs & Data)
Framework mapping	ISO 27001 A.5.18 Access rights, SOC 2 CC6.2, CIS Control 6.2
Audit period	2026-01-01 to 2026-06-30
Fieldwork completed	2026-08-03
Auditor	Internal Audit (GRC function)
Auditee	IT Manager, Head of Security
Related risk	R-04 (Terminated employee retains system access)

FINDING STATEMENT

Condition (what is)

Testing of control AC-02 (deactivation of user access within 1 business day of termination) identified that for 3 of 25 sampled terminations during the audit period, user access to the production platform, Salesforce CRM, and Okta remained active 9, 17, and 34 days after the recorded termination date in the HRIS. The 34-day instance involved a user with elevated privileges on the customer platform. No compensating monitoring detected the delayed deactivation.

Criteria (what should be)

NOVAtch's Access Control Standard v1.0, Section 4.2, requires that 'access to all NOVAtch systems is deactivated within 1 business day of the termination date recorded in the HRIS.' This standard operationalizes ISO/IEC 27001:2022 Annex A control A.5.18 (Access rights) and supports SOC 2 Trust Services Criterion CC6.2 (user access management).

Cause (why the gap)

Deprovisioning currently depends on the HR business partner manually raising a ticket to IT after processing a termination in the HRIS. No automated integration between the HRIS and the identity provider exists, and no detective control reconciles active identities against terminated employees. The three exceptions correlate with terminations processed during a two-week period in which the primary HR business partner was on leave and no formal backup process was in effect.

Consequence (so what)

Terminated individuals retained the ability to access confidential customer data (PII) and, in one case, privileged access to the production customer platform. This creates unauthorized-access exposure, a potential PIPEDA reporting trigger if any of the individuals had misused the retained access (data exfiltration or unauthorized modification), and audit findings that would materially impact SOC 2 or ISO 27001 certification readiness. The finding also represents realization of risk R-04 in the enterprise risk register, which had been treated as In Progress at the time of the audit period.

Recommendation

Address the cause through both technical and process controls:

- Implement HRIS-triggered automated deprovisioning to Okta and downstream systems, eliminating the manual ticket dependency (primary control)
- Until automation is in place, implement a weekly reconciliation control comparing HRIS terminations against active Okta identities, with exceptions triaged and closed within 24 hours (compensating control)
- Document a formal backup process for the HR business partner role including named backup, handoff protocol, and coverage confirmation during leave

- Extend the quarterly access review process (control AC-03) to include a specific check for accounts belonging to terminated employees

MANAGEMENT RESPONSE

The IT Manager and Head of Security have reviewed the finding and agree with the condition, criteria, and cause as stated. Management commits to the corrective actions below and notes that the underlying risk (R-04) had been identified prior to the audit and is being actively treated. The finding accelerates the automation timeline and adds the reconciliation compensating control that had not previously been scoped.

CORRECTIVE ACTION TRACKER

CA #	Action	Description	Owner	Due Date	Status
CA-01	Automated deprovisioning	Implement HRIS-to-Okta automated deprovisioning trigger; sunset the manual ticket process	IT Manager	2026-11-30	Open
CA-02	Weekly reconciliation	Reconciliation control comparing HRIS terminations to active Okta accounts; exceptions closed within 24 hours	IT Manager	2026-08-31	Open
CA-03	HR backup process	Documented backup for the HR business partner role covering all termination-related activities	Head of HR	2026-09-30	Open
CA-04	Access review extension	Add terminated-employee check to quarterly access review procedure and template	GRC	Next quarterly cycle	Open

Follow-up: verification of CA-01 and CA-02 will be performed in the next audit cycle. Immediate remediation (deactivation of the three identified accounts) was completed within 24 hours of finding notification and is separately documented.